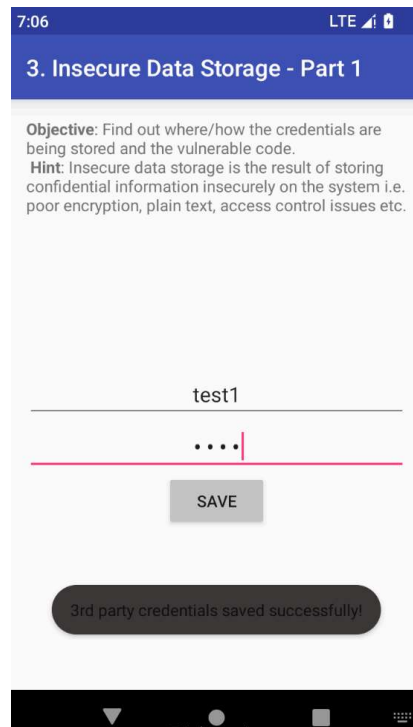


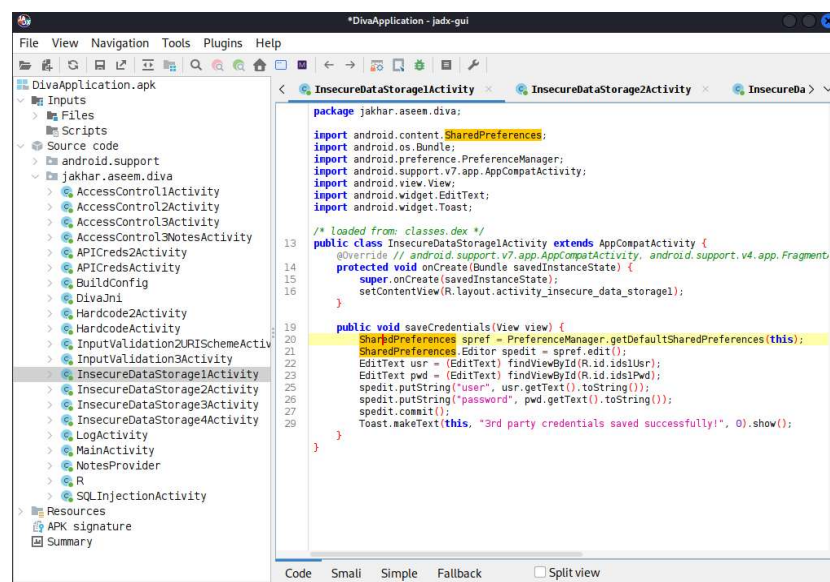
Challenge 3 - Insecure Data Storage part-1

In this task we have to find out where/how the credentials are being stored and the vulnerable code.



Here we have entered the password and username and it is showing the credentials are saved.

Now we need to check what is happening in the backend code and where is it saving.



So it shows the credentials are stored using **SharedPreferences**, which is a lightweight storage mechanism in Android for saving small amounts of data (e.g., user preferences, settings, or simple key-value pairs).

The **SharedPreferences** data is stored in an XML file in the app's private directory.

So run **adb shell** to access the shell and to check where this credentials are saved.

When we access **/data/data** using **"cd /data/data"** we can see many app directories

```
vbox86p:/data/data # ls
android
android.ext.services
android.ext.shared
com.aseem.diva
com.android.adservices.api
com.android.backupconfirm
com.android.bips
com.android.bluetooth
com.android.bluetoothhidservice
com.android.bookmarkprovider
com.android.calendar
com.android.calllogbackup
com.android.camera2
com.android.cameraextensions
com.android.castvoportallogin
com.android.carrierconfig
com.android.carrierdefaultapp
com.android.cellbroadcastreceiver.module
com.android.cellbroadcastservice
com.android.certinstaller
com.android.companiondevicemanager
com.android.connectivity.resources
com.android.contacts
com.android.cts.ctsshin
com.android.cts.priv.ctsshin
com.android.deskclock
com.android.dialer
com.android.development
com.android.dialer
com.android.documentsui
com.android.dreams.basic
vbox86p:/data/data # |
com.android.dreams.phototable
com.android.dynsystem
com.android.egg
com.android.emergency
com.android.externalstorage
com.android.gallery3d
com.android.hotspot2.osulogin
com.android.htmlviewer
com.android.insecureintentent
com.android.inputdevices
com.android.inputmethod.latin
com.android.intentsresolver
com.android.internal.display.cutout.emulation.corner
com.android.internal.display.cutout.emulation.double
com.android.internal.display.cutout.emulation.hole
com.android.internal.display.cutout.emulation.tall
com.android.internal.display.cutout.emulation.waterfall
com.android.internal.systemui.navbar.gestural
com.android.internal.systemui.navbar.gestural_extra_wide_back
com.android.internal.systemui.navbar.gestural_narrow_back
com.android.internal.systemui.navbar.gestural_wide_back
com.android.internal.systemui.navbar.threebutton
com.android.keyboard
com.android.launcher3
com.android.localtransport
com.android.location.fused
com.android.managedprovisioning
com.android.messaging
com.android.mms.service
com.android.modulemetadata
com.android.mtp
com.android.music
com.android.musicfx
com.android.nearby.halfsheet
com.android.networkstack
com.android.networkstack.tethering
com.android.nfc
com.android.ondrivepersonalization.services
com.android.onetimeinitializer
com.android.oms
com.android.packageinstaller
com.android.pacprocessor
com.android.permissioncontroller
com.android.phone
com.android.printservice.recommendation
com.android.printspooler
com.android.providers.blockednumber
com.android.providers.calendar
com.android.providers.contacts
com.android.providers.downloads
com.android.providers.downloads.ui
com.android.providers.media
com.android.providers.media.module
com.android.providers.settings
com.android.providers.telephony
com.android.providers.userdictionary
com.android.provision
com.android.proxyhandler
com.android.quicksearchbox
com.android.safetycenter.resources
com.android.se
com.android.server.telecom
com.android.settings
com.android.settings.intelligence
com.android.sharedstoragebackup
com.android.shell
com.android.sinsappdialog
com.android.smspush
com.android.soundpicker
com.android.statementservice
com.android.storagemanager
com.android.systemui
com.android.themes.font.notoserifsource
com.android.traceur
com.android.uwb.resources
com.android.vpndialogs
com.android.wallpaper.livesticker
com.android.wallpaperbackup
com.android.wallpapercropper
com.android.wallpaperpicker
com.android.webview
com.android.wifi.dialog
com.android.wifi.resources
com.genymotion.genyd
com.genymotion.settings
com.genymotion.superuser
com.genymotion.systempatcher
com.genymotion.tasklocker
jakhar.aseem.diva
org.chromium.webview_shell
```

Our application name is diva, so we can find the application using **grep** command

ls | grep 'diva'

```
vbox86p:/data/data # ls | grep 'diva'
jakhar.aseem.diva
vbox86p:/data/data # |
```

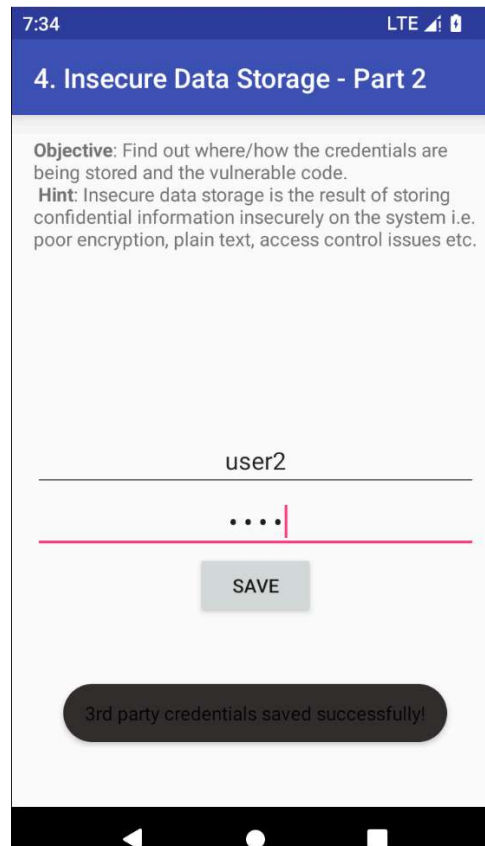
When we see inside that directory we can see a **shared_prefs** directory and inside we can see an **XML file**.

Let's find what is inside that XML file.

```
vbox86p:/data/data/jakhar.aseem.diva # cd shared_prefs/
vbox86p:/data/data/jakhar.aseem.diva/shared_prefs # ls
jakhar.aseem.diva_preferences.xml
vbox86p:/data/data/jakhar.aseem.diva/shared_prefs # cat jakhar.aseem.diva_preferences.xml
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
  <string name="password">abcd</string>
  <string name="user">test1</string>
</map>
vbox86p:/data/data/jakhar.aseem.diva/shared_prefs # |
```

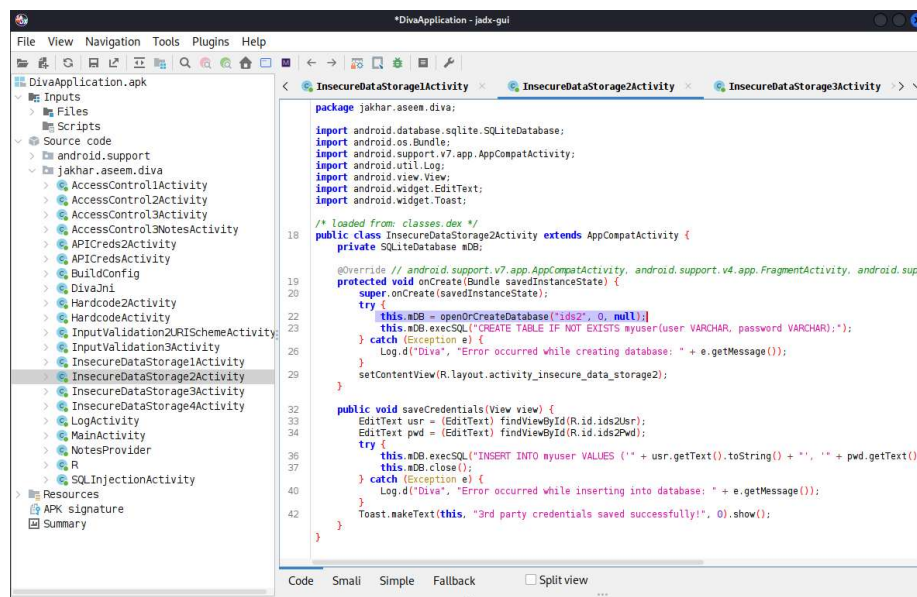
Here it shows the password and username we entered before.

Challenge 4 - Insecure Data Storage part-2



This is also similar task related to the old one, now we have to find where this credentials are saving and how it is stored.

Let's find the backend of the application oh how this code is working.



So here we can see that the credentials (username and password) are being stored in an **SQLite database**.

Also it shows the database name is **ids2**.

Let's access the shell of the adb, **adb shell**, and go to the directory **/data/data/jakhar.aseem.diva**

cd /data/data/jakhar.aseem.diva

```
vbox86p:/data/data/jakhar.aseem.diva # ls
cache  code_cache  databases  shared_prefs  uinfo5004053200321597416tmp  uinfo8105981959603965579tmp
vbox86p:/data/data/jakhar.aseem.diva #
```

Go to the databases folder and we will see the table name **ids2** and when we use **strings** command we can see the username and password.

```
vbox86p:/data/data/jakhar.aseem.diva # cd databases
vbox86p:/data/data/jakhar.aseem.diva/databases # ls
divanotes.db  divanotes.db-journal  ids2  ids2-journal
vbox86p:/data/data/jakhar.aseem.diva/databases # cd ids2
/system/bin/sh: cd: /data/data/jakhar.aseem.diva/databases/ids2: Not a directory
2|vbox86p:/data/data/jakhar.aseem.diva/databases # strings ids2
SQLite format 3
stablemyusermyuser
CREATE TABLE myuser(user VARCHAR, password VARCHAR)W
ctableandroid_metadataandroid_metadata
CREATE TABLE android_metadata (locale TEXT)
en_US
user21234
abcds12345
vbox86p:/data/data/jakhar.aseem.diva/databases #
```